

# R3M5 — Autenticació, autorització i middleware

Sessió **R3S5** · Microrepte per al **RA5** (CA: f, g, h). Aprendrem a protegir accions reals amb autenticació del framework, autorització mínima i middleware.

RA5.F

RA5.G

RA5.H



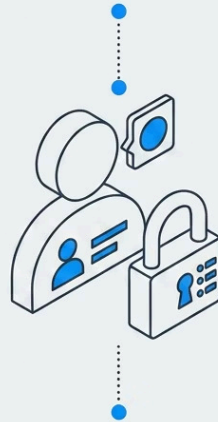
# Autenticació vs. Autorització

## AUTENTICACIÓ (qui ets?)



- login
- credencials
- identitat
- sessió

## AUTORITZACIÓ (què pots fer?)



- permisos
- rols
- accés a recursos
- política

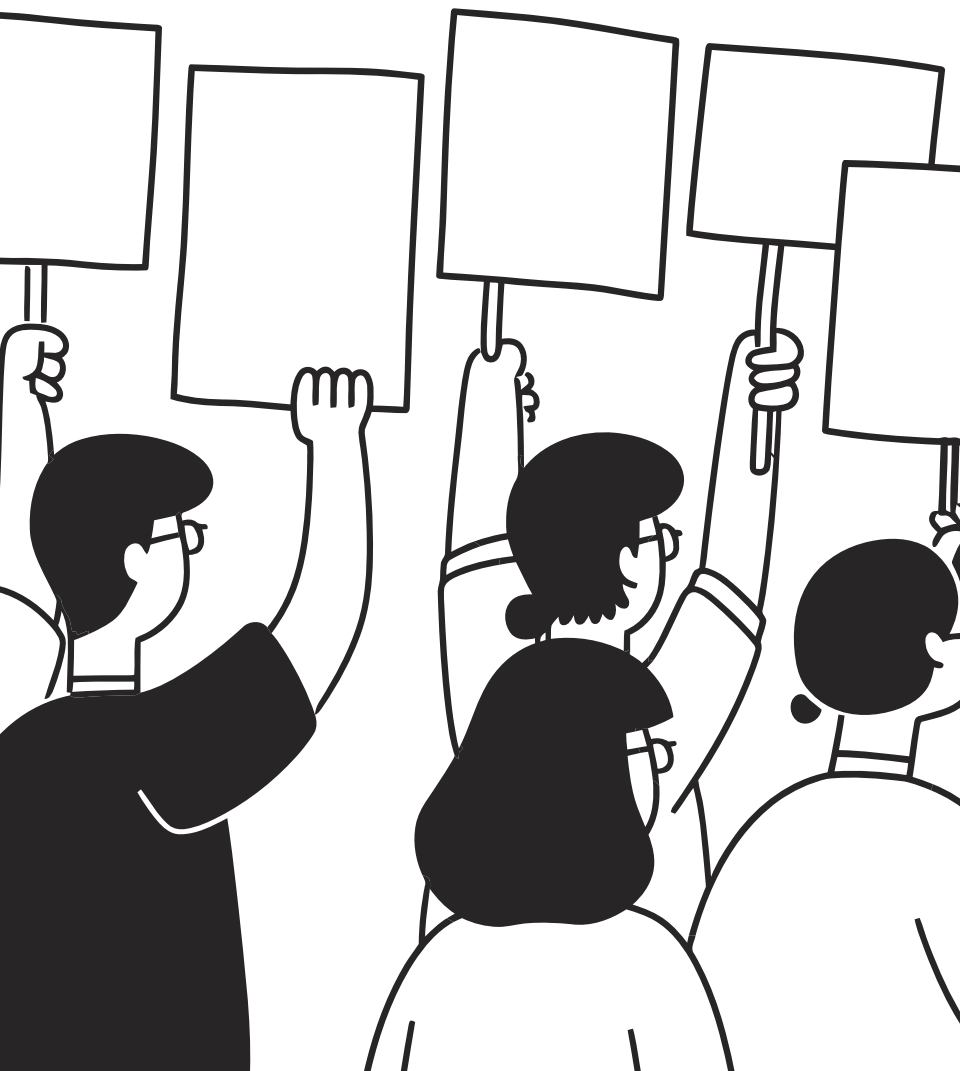
## La diferència clau

**Autenticació:** el sistema verifica qui ets. Necessites credencials vàlides per entrar.

**Autorització:** el sistema decideix què pots fer un cop has entrat. No tot usuari autenticat té els mateixos permisos.



Primer t'autentiques, *després* el sistema t'autoritza. L'ordre importa.



# Ocultar un botó *no* protegeix una ruta



## Protecció visual

El botó no apareix a la UI, però la ruta continua accessible des del navegador o eines com Postman.



## El risc real

Qualsevol usuari que conega la URL pot executar l'acció protegida simplement fent una petició directa.



## La solució

La protecció ha d'existir al servidor: middleware, guard o policy que rebutge la petició no autoritzada.

# Equivalències per framework

Cada framework ofereix els seus propis mecanismes. Trieu el que correspongui al vostre projecte **R3**.



## Laravel

- **Middleware:** filtra peticions abans d'arribar al controlador
- **Guard:** defineix com s'autentica l'usuari (session, token...)
- **Policy:** regles d'autorització per a un model concret



## Symfony

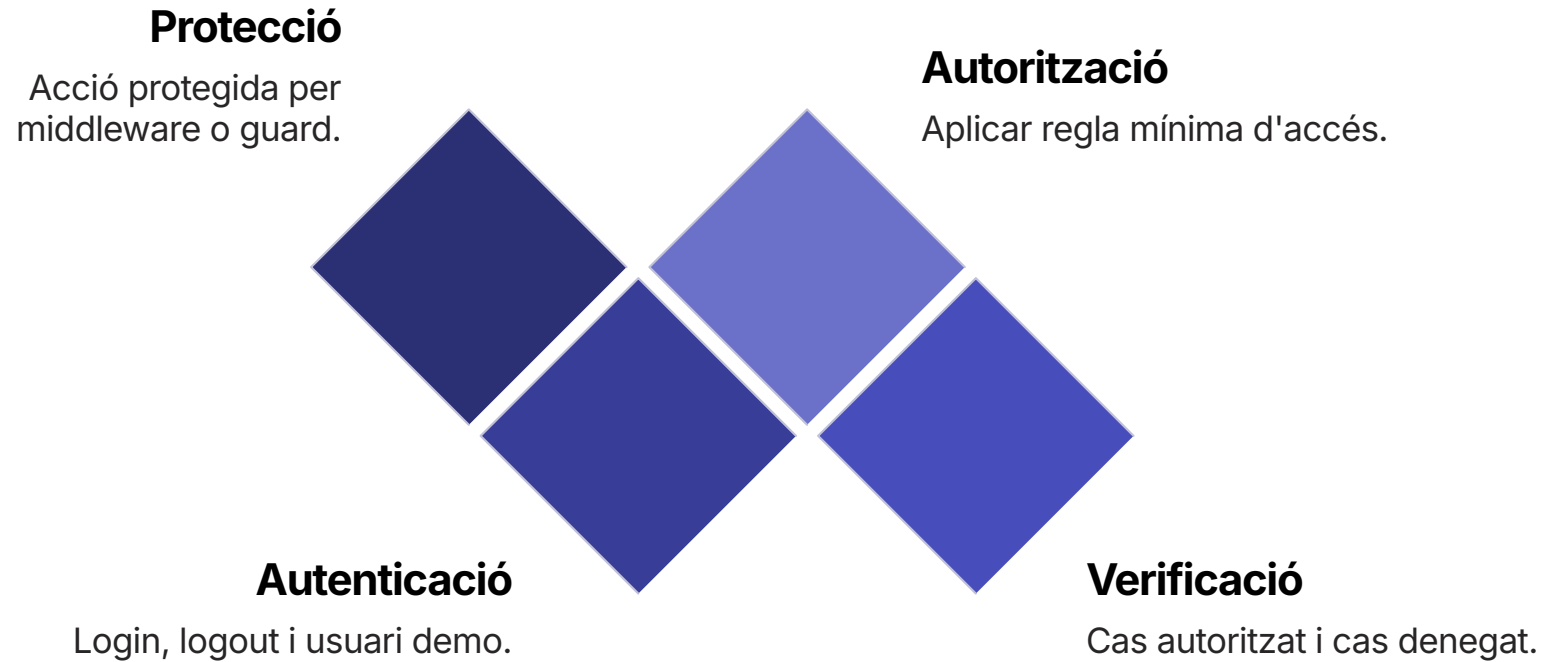
- **Security:** component central d'autenticació
- **Access Control:** restriccions per ruta en `security.yaml`
- **Voter:** lògica d'autorització personalitzada



## NestJS

- **Guard:** intercepta la petició i comprova permisos
- **Middleware:** processa la petició abans del guard
- **Decorator / Pipe:** enriqueix i valida les dades entrants

# Què heu de construir



El producte ha d'incloure totes les peces: sense instruccions de prova clares, el cas denegat no es pot avaluar.

# Detall de les tasques

01

---

## Login o mecanisme equivalent

Formulari, token o capçalera que acredite la identitat de l'usuari davant el servidor.

02

---

## Logout o invalidació de sessió

L'usuari ha de poder desconnectar-se i la sessió ha de quedar inutilitzable.

03

---

## Usuari demo documentat

Credencials de prova accessibles al README perquè el corrector pugui entrar sense configuració extra.

04

---

## Acció protegida amb regla d'autorització

Una acció real de R3 protegida al servidor amb almenys una condició d'autorització mínima.

05

---

## Instruccions de prova (cas OK i cas KO)

Indiqueu exactament com reproduir l'accés autoritzat i el rebuig. Sense això, l'avaluació no és possible.

# Errors habituals

## Protecció només visual

Amagar botons o enllaços sense protegir la ruta al servidor. La petició directa continua funcionant.

## Rols definits però no usats

Crear rols a la base de dades sense aplicar cap comprovació real al codi del servidor.

## No provar el cas denegat

Lliurar sense demostrar que un usuari no autoritzat rep un error 403 o equivalent.

## Secrets reals versionats

Pujar contrasenyes, tokens o claus d'API reals al repositori. Useu `.env.example` i `.gitignore`.



# Checklist final R3M5

Reviseu cada punt abans de lliurar. Si algun no es pot marcar, el microrepte queda incomplet.

## Autenticació i sessió

- ☐ Login implementat al servidor
- ☐ Logout o invalidació de sessió
- ☐ Usuari demo documentat al README

## Autorització

- ☐ Acció de R3 protegida per middleware/guard/policy
- ☐ Regla d'autorització mínima activa

## Verificació

- ☐ Cas autoritzat documentat i reproductible
- ☐ Cas denegat documentat i reproductible (error 403)
- ☐ Cap secret real al repositori

✅ Fora de l'àmbit: OAuth, 2FA, JWT avançat, sistema complet de rols, API completa.